

Varnostna politika vsebuje cilje varovanj informacij, področje veljavnosti, pravila in smernice, postopke in ukrepe ob varnostnih incidentih. Zaposleni so dolžni upoštevati varnostna pravila, so odgovorni za varna gesla in dolžni prijaviti varnostne incidente. Politika pokriva glavne grožnje. Napisana je tako, da jo lahko razumejo vse osebe, tudi ne-tehnično zaposlene.

Politika fiktivnega podjetja:

1. Namen in cilji politike

Namen te varnostne politike je zagotoviti osnovno zaščito informacijskih sistemov, podatkov in infrastrukture podjetja. Cilj politike je zmanjšati tveganje zlorab, izgub podatkov in varnostnih incidentov ter zagotoviti zanesljivo in varno delovanje sistemov, ki jih podjetje uporablja pri vsakodnevnem delu.

2. Področje uporabe

Ta politika velja za:

- vse zaposlene in zunanje sodelavce podjetja,
- vse informacijske sisteme, strežnike, razvojna okolja in repozitorije,
- vso strojno in programsko opremo v lasti ali uporabi podjetja,
- vse podatke, ki jih podjetje obdeluje ali shranjuje.

3. Odgovornosti zaposlenih in vodstva

Zaposleni so odgovorni za:

- varno uporabo svojih uporabniških računov in gesel,
- zaščito dostopov (API ključi, SSH ključi, tokeni),
- spoštovanje pravil glede dostopa do sistemov,
- takojšnje poročanje o sumu varnostnega incidenta.

Vodstvo je odgovorno za:

- omogočanje osnovnih varnostnih ukrepov,
- zagotavljanje ustreznih orodij in dostopov,
- sprejemanje odločitev ob večjih varnostnih incidentih.

4. Pravila za uporabo sistemov in gesel

- Vsak uporabnik mora imeti svoj lasten račun.
- Gesla morajo biti močna in unikatna (uporaba password managerja je priporočena).
- Uporaba 2FA je obvezna, kjer je to mogoče.
- Skrivnosti (gesla, API ključi) ne smejo biti zapisane v izvorni kodi ali javnih repozitorijih.
- Dostopi se dodeljujejo po principu najmanjših pravic (least privilege).

5. Postopki ob varnostnih incidentih

V primeru varnostnega incidenta (vdor, izguba podatkov, kompromitiran račun):

1. Incident se nemudoma prijavi vodstvu ali odgovorni osebi.
2. Dostopi, ki so lahko ogroženi, se začasno onemogočijo.
3. Izvede se analiza vzroka incidenta.
4. Po potrebi se zamenjajo gesla, ključi in dostopi.
5. Sprejmejo se ukrepi za preprečitev ponovitve incidenta.

6. Spremljanje in zagotavljanje skladnosti

- Upoštevanje politike se preverja občasno in po potrebi (npr. ob incidentih).
- Politika se pregleda in po potrebi posodobi vsaj enkrat letno.
- Vsak zaposleni je dolžan politiko upoštevati, kršitve pa se obravnavajo individualno.

Refleksija:

Za večje organizacije pokaže, da so njene prednosti jasna struktura in dobra pokritost varnostnih tveganj. Slabost je, da so pogosto preobsežne in težko razumljive (še posebej za ne tehnične zaposlene), kar lahko vpliva na njihovo upoštevanje.

Varnostna politika za moje fiktivno podjetje je zasnovana bolj praktično, in prilagojeno IT razumevanju. Osredotoča se na varno upravljanje dostopov, uporabo močnih gesel, zaščito skrivnosti in postopke ob varnostnih incidentih.

Zaposlenim bi politiko predstavil na uvodnem sestanku in povzel najpomembnejša pravila. Poudarek je na razumevanju in ne samo formalnem pregledu dokumenta.

Izvajanje politike bi spreminjal skozi prakso in ob incidentih. Posodabljala bi se tudi glede na spremembe v načinu dela in ob zaznavanju varnostnih pomankljivosti.